



# **INGENIERÍA EN COMPUTACIÓN**



## **SEGURIDAD INFORMÁTICA BÁSICA**

### **TAREA 1: LOS 11 PASOS DE LA METODOLOGÍA DE PERFILES DE PROTECCIÓN BASADA EN LOS CRITERIOS COMUNES**

#### **INTEGRANTES:**

**CHILPA NAVARRO ALAN SALVADOR- 319207738**

**MEDINA RUBALCAVA NATALIA MICHELL - 319207336**

**MURILLO RODRÍGUEZ SARAH SOFIA- 422130448**

**ORTEGA DE LA PAZ RAFAEL - 420054085**

**ROMERO GARCÍA DIANA SOFÍA - 319339264**

**GRUPO : 2**

**SEMESTRE: 2027-1**

**PROFESORA: DRA. CINTIA QUEZADA REYES**

**FECHA: 8 SEPTIEMBRE 2026**

## **¿Qué es un Perfil de Protección?**

Un Perfil de Protección es un documento que explica las necesidades y condiciones de seguridad que deben cumplir ciertos tipos de productos o sistemas tecnológicos. Por ejemplo, se puede crear un Perfil de Protección para firewalls, sistemas operativos, dispositivos de red, tarjetas inteligentes o sistemas de control de acceso.

Una cosa importante es que el Perfil de Protección no depende de una implementación específica. Esto quiere decir que indica qué condiciones de seguridad deben cumplirse, pero no menciona necesariamente una marca o producto en concreto.

En un Perfil de Protección se tienen en cuenta principalmente dos tipos de requisitos:

- Los requisitos funcionales de seguridad, llamados SFR (Security Functional Requirements), indican las funciones que debe tener el producto para ofrecer seguridad. Estas pueden incluir autenticación, control de acceso, protección de datos, privacidad o herramientas criptográficas.
- Los requisitos de aseguramiento de seguridad, conocidos como SAR (Security Assurance Requirements), muestran las pruebas y métodos necesarios para demostrar que las funciones de seguridad están bien implementadas.

## **¿Qué son los Criterios Comunes?**

Los Criterios Comunes para la Evaluación de la Seguridad de las Tecnologías de la Información, también llamados Common Criteria, surgieron a partir de unir varios modelos de evaluación de seguridad que se usaban antes en Estados Unidos, Europa y Canadá. Más tarde, se convirtieron en un estándar mundial con el documento ISO/IEC 15408.

Su principal objetivo es ofrecer un marco común para definir, crear y comprobar las características de seguridad de los productos de tecnología de la información. Estos productos pueden ser software, hardware o firmware. Los Criterios Comunes ayudan a ver si los requisitos de seguridad de un producto están bien establecidos, si se han hecho correctamente y si el proceso de desarrollo da un cierto nivel de confianza en su seguridad.

## **Los 11 pasos de la metodología de perfiles de protección basada en los criterios comunes:**

### **1. Introducción**

El primer paso es reconocer correctamente el Perfil de Protección y dar una visión general de lo que contiene. En esta parte se incluyen los datos que ayudan a identificar y categorizar el documento, así como una explicación general del producto, sistema o tecnología que se quiere proteger.

La descripción tiene que permitir que alguien entienda rápidamente cuál es el objetivo del Perfil de Protección y si es útil para las necesidades de su empresa. Por ejemplo, si se crea un Perfil de Protección para un firewall empresarial, en la introducción se debe decir que el documento se refiere a dispositivos que gestionan y filtran las comunicaciones entre distintas redes.

## **2. Descripción del objeto de evaluación**

En este paso se define el Objeto de Evaluación, también llamado TOE (Target of Evaluation). El TOE representa el producto, el sistema, el componente de software, el hardware o el conjunto de elementos que serán sometidos a evaluación.

La descripción debe indicar claramente qué componentes forman parte del Objeto de Evaluación y cuáles quedan fuera de sus límites. También debe explicar las funciones principales y las características del Objeto de Evaluación. Definir correctamente esta frontera es importante porque permite establecer qué elementos serán responsables de proporcionar funciones de seguridad determinadas. Por ejemplo, en un sistema de autenticación, el servidor de autenticación podría formar parte del TOE, mientras que la infraestructura física del centro de datos podría considerarse parte del entorno.

## **3. Entorno de seguridad**

En este apartado se revisa el contexto donde operará el objeto de evaluación. El entorno puede incluir usuarios, equipos, sistemas operativos, redes, instalaciones físicas, programas y otros elementos que interactúan directa o indirectamente con el TOE.

El análisis del entorno debe centrarse en tres cosas: las hipótesis de seguridad, las amenazas presentes y las políticas de seguridad de la organización. Este análisis ayuda a entender las condiciones reales en las que operará el sistema y a decidir las medidas de seguridad que se necesitarán después.

## **4. Hipótesis**

Las hipótesis muestran las condiciones que el entorno donde funcionará el objeto de evaluación que debe cumplir. Estas condiciones pueden incluir aspectos físicos, administrativos, humanos o tecnológicos. Por ejemplo, se puede suponer que solo el personal autorizado tiene acceso físico a los servidores o que los administradores tienen la capacitación necesaria para configurar correctamente el sistema.

Cada hipótesis debe identificarse claramente y relacionarse con las características del entorno del TOE. Las hipótesis son importantes porque existen condiciones de seguridad que no pueden controlarse directamente por el producto evaluado y dependen de factores externos.

## **5. Amenazas**

El quinto paso es identificar las amenazas que podrían afectar los activos relacionados con el objeto de evaluación. Una amenaza es cualquier situación o acción que pueda poner en riesgo la confidencialidad, integridad o disponibilidad de la información o de los recursos tecnológicos.

Para analizar una amenaza, es importante considerar varios factores, como el atacante, sus conocimientos técnicos, los recursos que tiene disponibles, sus motivaciones y los métodos que podría usar para llevar a cabo un ataque. Algunos ejemplos comunes de amenazas son:

- Acceso no autorizado a sistemas o datos.

- Robo de información sensible.
- Modificación no permitida de datos.
- Instalación de software malicioso.
- Ataques de denegación de servicio.
- Uso indebido de privilegios de acceso.

Cada amenaza debe tener un nombre o identificación clara. Esto permite relacionarla después con los objetivos y requisitos de seguridad que se hayan definido.

## **6. Políticas de seguridad de la organización**

Después de reconocer las amenazas se definen las políticas de seguridad que se deben seguir. Una política de seguridad es un conjunto de reglas que indican cómo se debe proteger la información, cómo se deben usar los recursos tecnológicos y qué acciones son permitidas o prohibidas.

Por ejemplo, una empresa puede decidir que todos los usuarios deben iniciar sesión antes de ver información sensible o que ciertos datos deben guardarse con métodos de cifrado. Las políticas deben estar bien definidas para poder vincularlas después con los objetivos de seguridad.

## **7. Objetivos de seguridad**

En este paso se decide qué condiciones deben cumplirse para enfrentar las amenazas y seguir las reglas ya establecidas.

Los objetivos se separan en dos grupos principales.

- Los objetivos de seguridad para el objeto de evaluación son las medidas que el producto o sistema debe aplicar directamente.
- Los objetivos de seguridad para el entorno son las medidas que se deben cumplir con elementos externos al TOE.

Por ejemplo, un objetivo del TOE puede ser bloquear una cuenta después de varios intentos de autenticación incorrectos. En cambio, un objetivo del entorno puede ser mantener físicamente protegido el servidor donde funciona el sistema. Los objetivos también se clasifican en funciones preventivas, detectivas y correctivas.

## **8. Requerimientos de seguridad**

Una vez establecidos los objetivos se determinan los requisitos concretos que deberá cumplir el sistema. Los Criterios Comunes distinguen principalmente dos categorías.

- Los requerimientos funcionales: especifican qué funciones de seguridad deberá proporcionar el objeto de evaluación.
- Los requerimientos de garantía o aseguramiento: establecen qué evidencias deberán proporcionar confianza en que las funciones de seguridad fueron correctamente diseñadas, desarrolladas y evaluadas.

Para seleccionar estos requisitos debe considerarse el valor de los activos que se desean proteger y el nivel de seguridad requerido. Entre los requisitos funcionales pueden

encontrarse: control de acceso, identificación y autenticación, auditoría de seguridad, protección de datos, comunicaciones seguras y funciones criptográficas.

## 9. Justificación

Demuestra que existe una relación lógica entre los elementos desarrollados anteriormente. En esta etapa debe comprobarse que los objetivos de seguridad permiten enfrentar las amenazas identificadas y cumplir las políticas establecidas.

También debe demostrarse que los requisitos de seguridad seleccionados permiten alcanzar los objetivos definidos. En términos simples, debe existir una relación similar a la siguiente:

***Amenazas → Objetivos de seguridad → Requisitos de seguridad***

Esta trazabilidad facilita la evaluación del Perfil de Protección y permite verificar que ninguna amenaza importante haya quedado sin una medida de seguridad correspondiente.

## 10. Definición de arquitectura

En esta etapa se diseña la arquitectura de seguridad necesaria para satisfacer los requisitos identificados. Se seleccionan los mecanismos, tecnologías y herramientas que permitirán implementar las medidas de protección. La arquitectura debe considerar la protección del propio objeto de evaluación y de los componentes relacionados con su funcionamiento.

Por ejemplo, pueden seleccionarse: firewalls, sistemas de autenticación, mecanismos criptográficos, sistemas de detección de intrusiones, controles de acceso, sistemas de respaldo y herramientas de auditoría. La arquitectura debe mantener una relación directa con los objetivos y políticas definidos previamente.

## 11. Implementación

El último paso consiste en llevar a la práctica los mecanismos de seguridad seleccionados durante el diseño de la arquitectura. En esta etapa se instalan y configuran las herramientas de acuerdo con las especificaciones técnicas y las políticas de seguridad establecidas.

También deben realizarse las pruebas correspondientes para comprobar que los controles funcionan correctamente y que permiten satisfacer los requerimientos definidos. La implementación representa la aplicación práctica de todo el análisis desarrollado en las etapas anteriores.

## Referencias

- Centro Criptológico Nacional. (s. f.). *Criterios comunes*. CCN-CERT.  
[https://www.ccn-cert.cni.es/publico/seriesCCN-STIC/series/400-Guias\\_Generales/401-glosario\\_abreviaturas/index.html?n=323.html](https://www.ccn-cert.cni.es/publico/seriesCCN-STIC/series/400-Guias_Generales/401-glosario_abreviaturas/index.html?n=323.html)
- Comisión Europea. (2024). *Reglamento de Ejecución (UE) 2024/482 de la Comisión, de 31 de enero de 2024, por el que se establecen disposiciones de aplicación del Reglamento (UE) 2019/881 en lo concerniente a la adopción del esquema europeo de certificación de la ciberseguridad basado en los criterios comunes (EUCC)*. Diario

*Oficial de la Unión Europea.*

<https://www.boe.es/buscar/doc.php?id=DOUE-L-2024-80181>

- Common Criteria Recognition Arrangement. (2022). *Common Criteria for Information Technology Security Evaluation: Part 1—Introduction and general model* (CC:2022, Revision 1).  
<https://www.commoncriteriaportal.org/files/ccfiles/CC2022PART1R1.pdf>
- Microsoft. (2024). *Certificaciones de Criterios comunes*. Microsoft Learn.  
<https://learn.microsoft.com/es-es/windows/security/security-foundations/certification/windows-platform-common-criteria>
- Universidad Nacional Autónoma de México. (2001). *Criterios comunes para evaluación de seguridad de tecnología de la información* [Tesis]. Dirección General de Bibliotecas y Servicios Digitales de Información.  
<https://tesiunamdocumentos.dgb.unam.mx/pd2001/290766/290766.pdf>